

Compliance Metrics and Controls (Illustrative Excerpt)

This illustrative excerpt summarises incident-response service levels, reported incident volumes, the risk scoring method, and control coverage across the compliance programme. It is not an official standard.

Incident-Response Service Levels

Severity	Notify within	Owner	Review
Critical	24 hours	CISO	Monthly
High	72 hours	Security Lead	Quarterly
Medium	5 days	Team Lead	Quarterly
Low	30 days	Team Lead	Annually

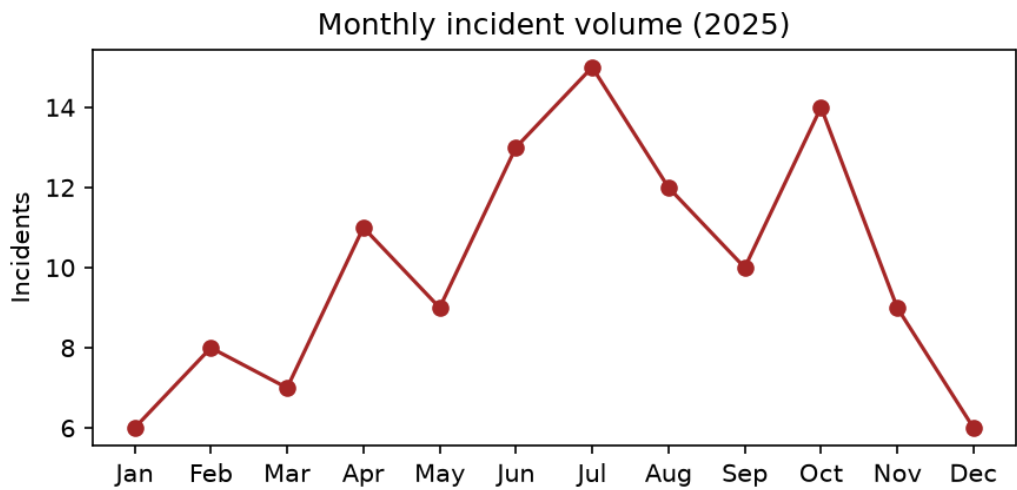
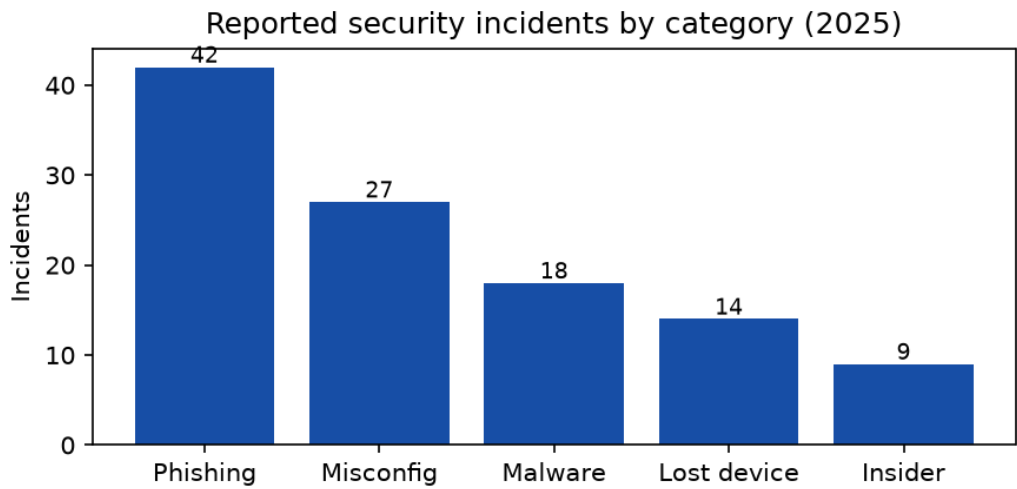
Risk Scoring

Each finding is scored using the formula below.

$$Risk\ Score = Likelihood \times Impact$$

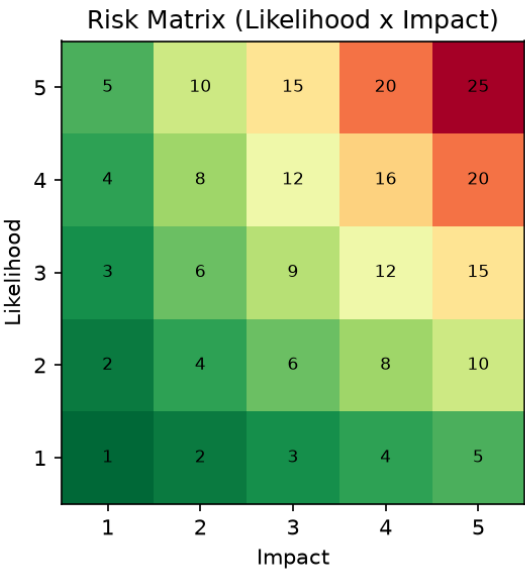
Reported Incidents (2025)

Incident volumes are tracked by category and monitored monthly for trends.



Risk Matrix

Inherent risk is rated on a five-by-five likelihood and impact matrix.



Residual Risk

Residual risk after controls is computed as follows.

$$Residual\ Risk = Inherent\ Risk \times (1 - Control\ Effectiveness)$$

Control Coverage

Control ID	Domain	Requirement	Status	Owner
C-1	Access	MFA on remote access	Implemented	Security Lead
C-2	Access	Least-privilege review	Partial	Team Lead
C-3	Data	Encryption at rest (PAN)	Implemented	CISO
C-4	Data	Retention limits enforced	Implemented	DPO
C-5	Logging	Centralised audit logs	Partial	SRE